SECSCAN · PANDUAN KESELAMATAN

Pengukuhan Keselamatan Joomla

Panduan praktikal mengukuhkan laman Joomla anda — daripada extension hingga sesi Super User.

Berdasarkan dokumentasi keselamatan rasmi Joomla, dipetakan kepada semakan automatik yang SecScan lakukan pada laman anda.

Edisi 2026 · Bahasa Melayu

Pengenalan

Joomla ialah CMS yang berkuasa tetapi kompleks. Menurut dokumentasi rasmi Joomla, majoriti kelemahan keselamatan berpunca daripada **sambungan pihak ketiga** (extension), bukan teras Joomla itu sendiri.

Panduan ini meringkaskan *Security Checklist* rasmi Joomla dan memetakannya kepada semakan automatik yang dilakukan SecScan pada laman anda. Tiga prinsip teras: **backup awal & kerap**, **kemas kini awal & kerap**, dan **guna hos yang selamat**.

Bagaimana SecScan membantu

SecScan mengimbas laman anda secara luaran (black-box) dan mengesan Joomla secara automatik. Bila Joomla dikesan, SecScan turut menyemak CVE terkini berkaitan teras dan sambungan, sijil TLS, header keselamatan, fail terdedah, dan konfigurasi DNS/e-mel. Panduan ini menerangkan cara membetulkan setiap isu yang SecScan mungkin laporkan.

1. Kemas kini awal & kerap

Kemas kini segera ke versi stabil terkini Joomla dan setiap sambungan pihak ketiga. Ini melindungi laman anda daripada kelemahan terbaru sebaik sahaja tampung dikeluarkan.

Sebelum memasang sebarang sambungan, semak Senarai Rasmi Sambungan Terdedah (Vulnerable Extensions List, vel.joomla.org). Langgan Joomla Security News untuk pengumuman terkini.

- Kemas kini teras Joomla & semua extension segera.
- Semak vel.joomla.org sebelum pasang extension baharu.
- Muat turun Joomla hanya dari downloads.joomla.org dan sahkan hash MD5.

2. Backup awal & kerap

Sediakan (dan uji) proses backup serta pemulihan yang berkala. Bila dilakukan dengan betul, ini memastikan anda boleh pulih daripada hampir mana-mana bencana. Prinsip utama: anda mesti sentiasa mampu memulangkan laman ke keadaan berfungsi sebelumnya.

- Backup fail + pangkalan data secara berjadual.
- Uji proses pemulihan, bukan sekadar simpan backup.
- Simpan salinan di lokasi berasingan daripada pelayan utama.

3. Kukuhkan akaun Super User

Tukar nama pengguna akaun admin lalai. Ini meningkatkan keselamatan akaun kritikal ini dengan ketara — penyerang perlu meneka dua pemboleh ubah (nama pengguna DAN kata laluan), bukan satu.

Hadkan bilangan akaun Super User, guna kata laluan kukuh, dan aktifkan pengesahan dua faktor yang disokong Joomla secara terbina.

- Tukar nama pengguna 'admin' lalai.
- Hadkan bilangan akaun Super User seminimum mungkin.
- Aktifkan Two-Factor Authentication terbina Joomla.

4. Fail .htaccess & konfigurasi pelayan

Joomla disertakan dengan fail .htaccess prakonfigurasi bernama htaccess.txt. Namakan semula kepada .htaccess dan letakkan di root laman anda melalui FTP untuk mengaktifkan perlindungan peringkat Apache.

- Namakan htaccess.txt → .htaccess di root laman.
- Tetapkan keizinan configuration.php kepada 644 (atau lebih ketat).
- Matikan paparan ralat PHP di pelayan produksi.

```
# di root Joomla, melalui FTP/SSH
mv htaccess.txt .htaccess
chmod 644 configuration.php
```

5. Kurangkan permukaan serangan extension

Kebanyakan kelemahan datang dari extension. Pasang hanya yang benar-benar perlu, dari pembangun yang dipercayai, dan nyahpasang sepenuhnya yang tidak digunakan (bukan sekadar nyahaktif).

- Pasang extension hanya dari sumber dipercayai (JED / vendor rasmi).
- Nyahpasang extension tidak digunakan sepenuhnya.
- Backup sebelum memasang atau mengemas kini sebarang extension.

6. HTTPS, header & sesi

Wajibkan HTTPS untuk seluruh laman, terutama kawasan pentadbir. Konfigur header keselamatan dan pastikan kuki sesi menggunakan atribut Secure dan HttpOnly untuk melindungi sesi log masuk.

- Wajibkan HTTPS (Global Configuration → Force HTTPS: Entire Site).
- Aktifkan header keselamatan (HSTS, X-Frame-Options, CSP).
- Pastikan kuki sesi Secure + HttpOnly.

7. Pemantauan & tindak balas

Keselamatan ialah proses berterusan yang memerlukan kewaspadaan. Pantau log pelayan, kesan perubahan fail, dan sediakan pelan tindak balas. Jika laman diserang, laporkan kelemahan kepada Joomla Security Task Force — jangan siarkan butiran penuh di forum awam kerana ia boleh membahayakan laman lain.

- Pantau access_log / error_log untuk corak serangan.
- Kesan perubahan fail teras yang tidak dijangka.
- Laporkan kelemahan baharu kepada Joomla Security Task Force, bukan forum awam.

Pemetaan: semakan SecScan → tindakan anda

Jadual di bawah memetakan setiap kategori semakan SecScan kepada tindakan pengukuhan Joomla yang berkaitan. Jalankan scan di laman SecScan, kemudian rujuk baris yang sepadan.

Semakan SecScan	Kaitan dengan keselamatan CMS anda
Technology / CVE	Mengesan Joomla & versinya, kemudian menyenaraikan CVE teras/extension terkini dari suapan NVD. Padankan dengan extension yang anda pasang; rujuk vel.joomla.org.
TLS/SSL	Menyemak sijil, versi protokol & cipher. Pastikan 'Force HTTPS' diaktifkan untuk seluruh laman.
Headers	Menyemak HSTS, CSP, X-Frame-Options, X-Content-Type-Options — melindungi kawasan Administrator daripada clickjacking & XSS.
Exposed Files	Mengesan fail terdedah seperti configuration.php, backup, atau htaccess.txt yang belum dinamakan semula.
Information Leakage	Mengesan tag generator/versi Joomla yang membantu penyerang menyasarkan CVE tertentu. Kaburkan maklumat versi.
DNS / Transport	Menyemak SPF/DMARC — penting untuk e-mel notifikasi & pendaftaran pengguna Joomla.
Cookies	Menyemak atribut Secure/HttpOnly/SameSite pada kuki sesi — melindungi sesi Super User.

Senarai semak pantas

Cetak dan tandakan setiap item sebagai audit minimum:

- ■ Teras Joomla & semua extension dikemas kini ke versi terkini
- ■ Extension disemak terhadap vel.joomla.org sebelum dipasang
- ■ Extension tidak digunakan telah dinyahpasang sepenuhnya
- ■ Backup berjadual berjalan dan telah diuji pulih
- ■ Nama pengguna Super User lalai telah ditukar
- ■ Two-Factor Authentication diaktifkan
- ■ htaccess.txt telah dinamakan semula kepada .htaccess
- ■ configuration.php diset kepada keizinan 644
- ■ Force HTTPS diaktifkan untuk seluruh laman
- ■ Paparan ralat PHP dimatikan di produksi
- ■ Scan SecScan dijalankan dan semua isu Kritikal diselesaikan

Nota: keselamatan ialah pengurangan risiko, bukan penghapusan risiko. Kekalkan sandaran (backup) yang diuji dan kemas kini kerap. Panduan ini bahan rujukan — sahkan setiap arahan pada persekitaran anda.